EEBus Technical Specification

SHIP Requirements for Installation Process

Version 1.0.0

Cologne, 2024-07-29

EEBus Initiative e.V.
Deutz-Mülheimer-Straße 183
51063 Cologne
GERMANY

Rue d'Arlon 25
1050 Brussels
BELGIUM

Phone: +49 221 / 715 938 - 0
Fax: +49 221 / 715 938 - 99

info@eebus.org
www.eebus.org

District court: Cologne
VR 17275

The EEBus concept was developed as part of E-Energy.

Supported by: Federal Ministry of Economics and Technology on the basis of a decision by the German Bundestag

Table of contents

List of figures

List of tables

1 Scope of the document

This document focuses on certain requirements for EEBUS SHIP nodes that must be fulfilled to be compliant with the EEBUS enhanced installation process.

The installation process itself is not part of this document. Rather, this document provides the technical basis for an installation process to identify, authenticate, and connect two devices in a secure way.

1.1 References

1.1.1 EEBUS documents

[SHIP]	*Minimum*: EEBus_SHIP_TS_Specification_v1.0.1.pdf *Recommended*: EEBus_SHIP_TS_Specification_v1.1.0.pdf Elements within this document that rely on the SHIP specification v1.1.0 are marked with "[1.1.0]"
[SPINE]	EEBus_SPINE_V1.3.0_Final.zip

1.1.2 Websites

[IANA PEN]	http://pen.iana.org/pen/PenApplication.page Website for requesting an IANA PEN.

1.1.3 Normative references

[ISO10646]	Standard for the Universal Coded Character Set (UCS), e.g. UTF-8
[RFC2119]	IETF RFC 2119: 1997, Key words for use in RFCs to indicate requirement levels Please see section 1.3.1 for details.
[RFC3927]	Dynamic Configuration of IPv4 Link-Local Addresses https://datatracker.ietf.org/doc/html/rfc3927
[RFC4291]	IP Version 6 Addressing Architecture https://datatracker.ietf.org/doc/html/rfc4291
[RFC4862]	IPv6 Stateless Address Autoconfiguration https://datatracker.ietf.org/doc/html/rfc4862
[RFC5480]	Elliptic Curve Cryptography Subject Public Key Information https://datatracker.ietf.org/doc/html/rfc5480
[RFC7366]	Encrypt-then-MAC for Transport Layer Security (TLS) and Datagram Transport Layer Security (DTLS) https://datatracker.ietf.org/doc/html/rfc7366

[RFC7468] Textual Encodings of PKIX, PKCS, and CMS Structures
https://www.rfc-editor.org/rfc/rfc7468

[RFC8447] IANA Registry Updates for TLS and DTLS
https://datatracker.ietf.org/doc/html/rfc8447

[RFC9371] Registration Procedures for Private Enterprise Numbers
https://www.rfc-editor.org/rfc/rfc9371.html

1.2 Terms and definitions

DHCP
Abbreviation for "Dynamic Host Configuration Protocol". DHCP allows connected clients to be integrated into an existing network without manual configuration of the network interface. Necessary information such as IP address, netmask, gateway, name server (DNS) and any other settings are assigned automatically.

DSO
Abbreviation for "Distribution System Operator". A DSO operates and manages the local and regional energy distribution networks.

ECC
Abbreviation for "Elliptic Curve Cryptography"

EMS
Abbreviation for "Energy Management System"

EV
Abbreviation for "Electric Vehicle"

EVSE
Abbreviation for "Electric Vehicle Supply Equipment"

GCP
Abbreviation for "Grid Connection Point"

GCPH
Abbreviation for "Grid Connection Point Hub"

HVAC:
Abbreviation for "Heating, Ventilation and Air Conditioning"

IANA PEN
Abbreviation for "Internet Assigned Numbers Authority - Private Enterprise Numbers"

IP
Abbreviation for "Internet Protocol"

LPC
Short name of the Use Case "Limitation of Power Consumption"

QR code
"Quick Response" Code, a two-dimensional, electronically readable code

SHIP
Smart Home IP - An IP-based protocol for secure machine-to-machine communication in home automation and further domains developed by the EEBus Initiative e.V.

SKI
Abbreviation for "Subject Key Identifier"

SPINE
Smart Premises Interoperable Neutral-message Exchange: Technical Specification of EEBus Initiative e.V.

TXT record
With a TXT record, a freely definable text can be stored in a DNS zone.

1.3 Requirements

1.3.1 Requirements wording

The following keywords are used:

- SHALL
- SHALL NOT
- SHOULD
- SHOULD NOT
- MAY

Note: They apply only if written in capital letters.

For the meaning of the keywords, please refer to [RFC2119].

1.3.2 Requirements referencing

Throughout this document, all requirements SHALL be marked with the following abbreviation:

[SRIP-xyz]

e.g.: [SRIP-007]

The abbreviation is used to mark requirements of this document with a unique number xyz. These requirements may be referenced in this or other EEBUS documents.

2 SHIP connectivity requirements

2.1 IP address assignment

As different setups may occur in the field, a device supporting SHIP and SPINE SHALL follow the following rules regarding the IP address assignment:

- The device SHALL start with a DHCP-client active, searching the local network for a DHCP-server to assign an IP address for the device ([SRIP-210/1]).
  - This holds valid for IPv4 and IPv6.
- If this fails, the device SHALL use
  - for IPv4: [RFC3927] (Dynamic Configuration of IPv4 Link-Local Addresses), also known as Zeroconf, AUTOIP, IPv4 Link-Local (IPv4LL), Automatic Private IP Addressing (APIPA) or Internet Protocol Automatic Configuration (IPAC),
  - for IPv6:
    - [RFC4862] (IPv6 Stateless Address Autoconfiguration, SLAAC) or
    - IPv6 Link-Local (IPv6LL, see [RFC4291])

  to assign itself an IP address ([SRIP-210/2]).

Note: With IPv6, it is possible to have multiple addresses at the same time (e.g., an IPv6LL address as well as an address assigned via DHCP).

Additionally, the device SHOULD offer the possibility that the user MAY choose a static IP (v4 or v6) address ([SRIP-210/3]). However, this is only required in rare cases. Please note that a lack of this functionality may result in a device that cannot be integrated into certain networks.

It is recommended to support both IPv4 and IPv6 ([SRIP-210/4]).

2.2 SHIP TXT record content

As defined in [SHIP], the SHIP TXT record consists of the following key-value pairs:

- txtvers
- id
- path
- ski
- register
- ecc[1.1.0]
- brand
- type
- model

The following changes and additions are defined by this document:

General:

- All values SHALL be encoded in UTF-8 (as defined in [ISO10646]) ([SRIP-220/1]).
- The following characters are prohibited*[1]:

    - ";" (semicolon)
    - Characters belonging to the so-called "general category" definitions "Control", "Format", and "Separator".
        - Among others, this means white space characters SHALL NOT be used ([SRIP-220/2]).
        - As alternative to whitespaces it is recommended to use the hyphen-minus '-' (Unicode U+002D) instead ([SRIP-220/3]).

*[1]: Even though already released SHIP versions do not explicitly forbid using some of the above-mentioned characters in key values, future SHIP releases will probably prohibit their use.

For the key "id":

Within [SHIP], the following is defined:

> *The value of the* `id` *key contains a globally unique ID of the SHIP node and has a maximum length of 63 bytes. The first part of the unique ID SHOULD be an abbreviation of the manufacturer name. Behind the abbreviation, the manufacturer defines a unique identifier. The id value (SHIP ID) shall be unique.*

The quoted part of [SHIP] rather gives a recommendation on the content of "id" than a strict rule (except for the uniqueness and maximum lenght). Without breaking the rules of [SHIP], this document still keeps the uniqueness of the content of "id" and the specified length limitation, but imposes different rules on the format of "id": A SHIP node conforming to this specification SHOULD*[2] have an id key with a value matching the following format.

*[2]: For devices that are already sold, the SHIP ID SHOULD NOT be changed ([SRIP-220/4]), see section A.1 for more information. Newly manufactured devices that do not share a firmware with already sold devices SHALL use the new SHIP ID format ([SRIP-220/5]).

New SHIP-ID format:

```
i:<IANA PEN>_u:<VPID>
```

With:

- <IANA PEN> SHALL be set to one to six characters set to the manufacturer's [IANA PEN] ([SRIP-220/6])
- <VPID> SHALL be set to a globally unique ID ([SRIP-220/7]) for the given <IANA PEN> as in [SRIP-220/6]. This means that the tuple (<IANA PEN>, <VPID>) SHALL uniquely identify this SHIP device globally.
    - The VPID SHOULD be same as the device's serial number or a similar information that can be found printed on the device itself ([SRIP-220/8])

A SHIP node conforming to this specification SHALL NOT consider it an error if another SHIP node has a SHIP ID with a different format ([SRIP-220/9]).

An example of the newly defined SHIP-ID:

```
i:12345_u:123abc456def
```


For the key "brand":

If the key "brand" is set, its value SHALL be set to the name of the device's brand with up to 32 characters ([SRIP-220/10]). The brand name MAY correlate to the IANA PEN stated in [SRIP-220/6], if set there ([SRIP-220/11]), but may also be set to a different brand.

For the key "type":

The key "type" SHOULD be set to a human-readable string with up to 32 characters with the device's type (e.g., "Inverter"), to ease user's recognition of the correct SHIP-node ([SRIP-220/12]).

For the key "model":

The key "model" SHOULD be set to a human-readable string with up to 32 characters with the product model (e.g., "E1234"), to ease user's recognition of the correct SHIP-node ([SRIP-220/13]).

The **new key "serial"** SHOULD be set to the device's serial number or a similar information with up to 32 characters that can be found printed on the device itself, according to [SRIP-220/7] and [SRIP-220/8] ([SRIP-220/14]).

The **new key "cat"** (device **cat**egory) SHALL be set to the categories that apply for this device ([SRIP-220/15]). The value of cat SHALL be a string with comma-separated device category numbers without any whitespace ([SRIP-220/16]). The formal pattern of the value is

<dc>[,<dc>]*

where each <dc> is a placeholder for one category number. The value of cat SHALL NOT contain a category number more than once ([SRIP-220/17]). The following categories are defined:

Device category number <dc>*[3]	Description
1	**Grid Connection Point Hub** (GCPH) (e.g. a control unit from the public grid operator)
2	**Energy Management System** (EMS) (device managing the electrical energy consumption/production of connected devices in the building)
3	**E-mobility** related device (e.g., charging station)
4	**HVAC** related device/system (e.g., heat pump)
5	**Inverter** (PV/battery/hybrid inverter)
6	**Domestic appliance** (e.g., washing machine, dryer, fridge, etc.)
7	**Metering device** (e.g., smart meter or sub-meter with its own communications technology)

Table 1: Device categories

*[3]: The existing numbers will not change in subsequent versions of this specification. If new categories are needed, they will be added at the end of the list.

Example for the TXT record entry for "cat" for a device consisting of an EMS and an inverter:

```
cat=2,5
```

If the device's categorie(s) change(s) later on (e.g., in an inverter with integrated EMS functionality, the user deactivates the EMS because a separate EMS shall be used), the categorie(s) SHALL be changed accordingly ([SRIP-220/18]).

The updated overview of the SHIP TXT record key-value pairs, with examples:

Key	**Value**	**Example**	**Runtime Behavior**	**Required***[4]
txtvers	Version number	txtvers=1	Static	Mandatory
id	Identifier	id=i:12345_u:123abc456def	Static	Mandatory
path	String with wss path	path=/ship/	Static	Mandatory
ski	40 digit hexadecimal string representing the 160 bit secp256r1 SKI value	ski=5555AAAAFFFF1111CCCC3333EEEEDDDD99992222	Static/Dynamic[1.1.0]	Mandatory
register	Boolean	register=true	Dynamic	Mandatory
ecc[1.1.0]	Boolean	ecc=true	Dynamic	Mandatory for SHIP version ≥ 1.1
brand	String with brand	brand=ExampleBrand	Static	Mandatory*[5]
type	String with device type	type=Inverter	Static	Recommended
model	String with model	model=E1234	Static	Mandatory*[6]
serial	String with serial number	serial=123abc456def	Static	Recommended
cat	String with list of device categories	cat=2,5	Dynamic	Mandatory*[7]

Table 2: SHIP TXT record content with changes as described in this document

*[4]: Presence requirements in this table apply to the TXT record only. For presence requirements regarding the QR code please see section 3.1.

*[5]: Implementations conforming with this document SHALL set the key "brand" for their own TXT record ([SRIP-220/19]). However, implementations SHALL NOT consider it an error if this key is absent or empty in the TXT record of an other SHIP device ([SRIP-220/20]). The latter is relevant to keep compatibility with existing implementations that are based upon SHIP versions where this key is just recommended.

*[6]: Implementations conforming with this document SHALL set the key "model" for their own TXT record ([SRIP-220/21]). However, implementations SHALL NOT consider it an error if this key is

absent or empty in the TXT record of an other SHIP device ([SRIP-220/22]). The latter is relevant to keep compatibility with existing implementations that are based upon SHIP versions where this key is just recommended

*[7]: Implementations conforming with this document SHALL set the key "cat" for their own TXT record ([SRIP-220/23]). However, implementations SHALL NOT consider it an error if this key is absent in the TXT record of an other SHIP device ([SRIP-220/24]). The latter is relevant to keep compatibility with existing implementations that are based upon SHIP versions where this key was not defined.

2.3 SHIP registration

The following proposals for the SHIP registration (trust another SHIP device) are added with this document:

In case the EEBUS/SHIP functionality is activated in a device, the device SHALL*[1] announce its SHIP service via mDNS at least as long as it is able to establish a further SHIP connection*[2] ([SRIP-230/1]).

*[1]: Excluded from this requirement are devices with a type of GCPH (see [SRIP-220/15]) that are administrated to communicate with selected device(s). Such a GCPH device only needs to announce its service until the SHIP pairings to the configured devices are completed. However, this requires that such a GCPH device is responsible to (re-)initiate the SHIP connection to the paired device(s). All other devices still need to announce their service according to [SRIP-230/1].

*[2]: E.g. some devices might support at most two active SHIP connections in parallel. In this example, the SHIP service must be announced at least as long as no or just one SHIP connection is active.

Trusting another SHIP device means trusting that device's SKIs or public keys or certificates. In general, [SHIP] defines methods to trust another device before a TLS handshake begins or successfully completes (so-called "pre-trust") or after the TLS handshake completion (so-called "post-trust"). The preferred method is "pre-trust" and explained with some examples:

Example: A SHIP device "A" displays to the user other SHIP devices that have been found using SHIP service discovery. For a selected device "B", the display shows the SKI(s) of device "B" and the user can decide to trust the device or not. See Annex A.2 for details on this example.

Example: The user/administrator of a SHIP device "A" already knows the SKI(s) etc. of the other SHIP device "B" (e.g. through the QR code of device "B"). The user/administrator configures device "A" to trust the SKI(s) of device "B".

Note: A SHIP device may implement more than one cryptographic curve, which results in more than one SKI and more than one certificate. For details on the curves and priority rules please see [SHIP].

Note: See Annex A.3 for details on "post-trust" as alternative approach. However, that approach is not required by this specification.

Once mutual trust between SHIP devices is established, SHIP devices can initiate a SHIP connection as soon as they (re-)discovered the required other SHIP device service via mDNS/DNS-SD.

Please also consider Annex B for further details and concepts on SHIP pairing.

3 QR code requirements

3.1 QR code for installation

Every device that uses SPINE over SHIP for communication and that wants to participate in the EEBUS enhanced installation process SHALL*[1] provide a QR code, as described in [SHIP]. The QR code can be located on the packaging, the device itself, on the device's display, in a smartphone app for the device or somewhere within the (printed) documentation. As with SHIP V1.1.0 the certicificate may be changed during runtime (see Annex A.5) (hence, the SKI may change) it is strongly recommended that mechanisms to update the QR code are provided (e.g., on the device's display or a smartphone app).

The QR code content described below SHALL

- either be provided as individual QR code (only containing the data as described below) ([SRIP-310/1])
- or be integrated into another QR code, containing the content below as well as further information ([SRIP-310/2]).

Within the EEBUS enhanced installation process the latter ([SRIP-310/2]) is only permitted, if

- this combined QR code is the only QR code provided with the device or
- the QC codes are clearly labeled and it can easily be identified where to find the EEBUS/SHIP content

Note: In case of a combined QR code, it is particularly important to consider the maximum size of QR codes.

An image MAY be added in the middle of the QR code to make it easier for the installer to select the correct QR code ([SRIP-310/3]) (see Figure 1 for an example).

The following rules are already stated in [SHIP] or impose additional requirements, without breaking rules of [SHIP]:

- The QR code SHALL include the SHIP-ID and the secp256r1 SKI ([SRIP-310/4]).
- A medium error correction SHOULD be used ([SRIP-310/5]).
- The size of the QR code SHOULD be at least 2cm by 2cm or 0.33mm/module (depending on which leads to a larger picture) ([SRIP-310/6]).

As defined in [SHIP], the PIN is a mandatory part of the QR code, if the SHIP node has a PIN. As the PIN is not retrievable via the TXT record, it is important for an installer tool to retrieve the PIN via the QR code. Otherwise the installer would need to enter the PIN manually in the installer tool.

The content of the QR code SHALL be structured as follows ([SRIP-310/7]):

- SHIP;
- SKI:<secp256r1 SKI>;*[2]
- [PIN:<PIN>;]*[2]
- ID:<SHIP ID>;
- [BRAND:<brand as in [SRIP-220/10]>;]
- [TYPE:<type as in [SRIP-220/12]>;]

- [MODEL:<model as in [SRIP-220/13]>;]
- [BSKI:<brainpoolP256r1 SKI>;][1.1.0]
- [B2SKI:<brainpoolP384r1 SKI>;][1.1.0]
- [PKEY:<public key for secp256r1>;]*[3]
- [PBKEY:<public key for brainpoolP256r1>;]*[3, 1.1.0]
- [PB2KEY:<public key for brainpoolP384r1>;]*[3, 1.1.0]
- [CERTURL:<URL to public certificate for secp256r1>;]*[4]
- [CERTBURL:<URL to public certificate for brainpoolP256r1>;]*[4, 1.1.0]
- [CERTB2URL:<URL to public certificate for brainpoolP384r1>;]*[4, 1.1.0]
- [SERIAL:<serial as in [SRIP-220/14]>;]
- [CAT:<cat as in [SRIP-220/15]>;]
- [NOMINALPOWER:<nominal production power>,<nominal consumption power>;]*[5]
- [<further key-value pairs>;]*[6]
- ENDSHIP;*[7]

Key-value pairs in **square brackets** are **optional** within the QR code. For presence requirements regarding the TXT record please see section 2.2.

The ";" (semicolon) is only permitted for the separation of the different key-value pairs and SHALL NOT be used otherwise ([SRIP-310/8]).

*[1]: Excluded from this requirement are devices with a type of GCPH (see [SRIP-220/15]).

*[2]: The SKI and the PIN SHALL be denoted as group of four characters each, with an additional space every 4 hexadecimal digits, as described in [SHIP] ([SRIP-310/9]).

*[3]: For a higher level of security, instead of only providing the SKI, the public key MAY be provided ([SRIP-310/10]). Providing the public key within the QR code only makes sense if the certificate URL as described in [SRIP-310/11] is NOT provided. For further details on the public key representation in the QR code please refer to section 3.2.1.

[4]: For a higher level of security, instead of only providing the SKI, the public certificate SHOULD[8] be provided as file for download from a given URL ([SRIP-310/11]). Providing the certificate URL within the QR code only makes sense if the public key as described in [SRIP-310/10] is NOT provided. For further details on the URL representation in the QR code please refer to section 3.2.2.

*[5]: The value of this key SHALL have the format "<a>,<b>" (without double quotes) ([SRIP-310/12]). The absolute value of <a> expresses the absolute electrical nominal production power in watt. <a> SHALL be a negative integer value or zero ([SRIP-310/13]). The absolute value of <b> expresses the absolute electrical nominal consumption power in watt. <b> SHALL be a positive integer value or zero ([SRIP-310/14]). Examples are "-8000,0" (only feed-in possible) or "0,11000" (only consumption) or "-8000,11000" (all without double quotes).

*[6]: In future versions, further key-value pairs may be added. This SHALL be considered when interpreting the QR code by skipping unknown content at the end ([SRIP-310/15]).

*[7]: Implementations conforming with this document SHALL use the "ENDSHIP;" mark to indicate the end of the SHIP QR code data ([SRIP-310/16]). However, implementations SHALL NOT consider it an

error if this mark is absent in a SHIP QR code ([SRIP-310/17]). This is relevant to keep compatibility with existing SHIP QR codes that are based upon SHIP versions where this mark was not defined.

*[8]: This recommendation considers potential cases where a regulation authority may impose stronger rules to establish an initial trust. See also A.4.

An example for a QR code with a SHIP ID as defined in this document:

Text:

```
SHIP;SKI:5555 AAAA FFFF 1111 CCCC 3333 EEEE DDDD 9999
2222;PIN:5555 AAAA FF;ID:i:12345_u:123abc456def;BRAND:Example-
Brand;TYPE:Heatpump;MODEL:E1234;SERIAL:123abc456def;CAT:4;NOMIN
ALPOWER:0,11000;ENDSHIP;
```

The according image:

Figure 1: QR code example with SHIP ID as defined in this document, with EEBUS logo

3.2 QR code encoding details

3.2.1 Public key representation in QR code

The binary value of the public key is the value of the BIT STRING subjectPublicKey (excluding the tag, length, and number of unused bits) of the according X.509 certificate. In the QR code, the value SHALL be encoded as non-prefixed hexadecimal string in UTF-8 encoding with an additional space every 4 hexadecimal digits*[1] ([SRIP-321/1]). Upper or lower case letters MAY be used (0-9, A-F, a-f) ([SRIP-321/2]).

*[1]: Please note that this differs from the representation in the TXT record.

Note: Unlike SKI values used in SHIP, the length of the hexadecimal representation of a public key's binary value depends on the curve being used. In case of elliptic curves, the length also depends on the form being used within the certificate, as subjectPublicKey can take the compressed form or the uncompressed form of a public key (see section 2.2 of [RFC5480]).

Example:

- A given public key in uncompressed form may have this hexadecimal representation in the QR code:

```
0470 e317 9d36 bf8b c43b a058 1822 f5f7 61c5 3e70 2dc3 3a0a
f074 927f 7be4 3449 a856 0fd5 7ee4 ca9c fdd1 4ba4 f456 5b3b
```

```
9c04 82e8 3bc2 7246 ab80 8361 013a 7fdf 24ae cc36 2005 ad95
ddc9 a191 9017 7b01 55b5 d7b1 e83a 95a5 9fe9 4d8c 8f0a 2994 49
```

- The same public key in compressed form would have this hexadecimal representation in the QR code:

```
0370 e317 9d36 bf8b c43b a058 1822 f5f7 61c5 3e70 2dc3 3a0a
f074 927f 7be4 3449 a856 0fd5 7ee4 ca9c fdd1 4ba4 f456 5b3b 9c
```

Even though there are unique conversions between compressed and uncompressed form of a public key, the rules given above require the representation of a public key in a QR code having the same form as the the one in the according certificate. Among others, this simplifies a visual comparison of the string from the QR code with information extracted from the underlying certificate.

3.2.2 URL representation in QR code

The URL to the certificate file SHALL be unique for a given device and SHOULD contain the according SKI (e.g. "https://certs.example.org/dev/dev_xzy_<SKI>.pem") ([SRIP-322/1]). The URL itself SHALL NOT contain a semicolon (';') ([SRIP-322/2]).

The certificate file SHALL be provided in PEM format according to [RFC7468] ([SRIP-322/3]).

The certificate file MAY contain a certificate chain ([SRIP-322/4]). In this case, the device's own certificate SHALL be the first certificate in the file ([SRIP-322/5]). Each following certificate SHALL directly certify the one preceding it ([SRIP-322/6]).

Note: Tools like openssl may only recognize the first certificate in a PEM file.

Annex A - Supplementary information

A.1 Notes on SHIP ID changes

This section provides some important aspects for the event that a SHIP ID is changed.

By default, a SHIP ID is considered as unmutable identification of a SHIP device. As a certificate of a SHIP device might be updated during the device's lifetime[1.1.0], the corresponding SKI will also change. By contrast, the SHIP ID permits to find a SHIP device via mDNS/DNS-SD even if a certificate/SKI is updated. Particularly, searching for a known SHIP ID is the preferred method for re-establishing a connection after reboot or in case of connection interrupt.

If, for any reason, the SHIP ID was changed, it is not explicitly required to immediately close existing active connections with other SHIP nodes. It is also not explicitly required to remove the trust to other SHIP node's certificates. But it can be expected that reconnection problems might occur once the SHIP ID was changed.

To avoid negative user experience from changes of a SHIP ID, it is strongly advised to inform the user ahead of the SHIP ID change and to guide through the process of recreating trust to other SHIP nodes again.

In any case, changing the SHIP ID is considered a drastic change and should be avoided if possible!

A.2 SHIP/SPINE in the device's menu

A device using SPINE over SHIP SHALL*[1] provide a menu available for user interaction ([SRIP-A20/1]). This menu can be within the device's built-in user interface or within a smartphone/PC application.

*[1]: Excluded from this requirement are devices with a type of GCPH (see [SRIP-220/15]).

The according menu SHOULD be named "EEBUS" ([SRIP-A20/2]). The "EEBUS" menu SHOULD be located within the general settings menu ([SRIP-A20/3]).

The EEBUS menu SHALL have a sub-menu where all*[2] SHIP devices found in the network are listed ([SRIP-A20/4]). When selecting one of the found devices in the list, a new menu SHALL open with further information on the device (see below) and the possibility to initiate a SHIP connection to this device ([SRIP-A20/5]).

*[2]: The list MAY be filtered so that only other SHIP devices are listed that the device can make a useful connection to ([SRIP-A20/6]).

When displaying the available SHIP devices, the SHIP ID and the SKI SHALL be stated ([SRIP-A20/7]). The additional information "brand", "type", "model" and "serial" SHOULD be visible, if provided ([SRIP-A20/8]). SHIP devices SHOULD be sorted by "type" with according headings ([SRIP-A20/9]). Which of the information is contained in the overview list of found devices, and which information is only stated when selecting one of the list entries, is up to the manufacturer, but it is recommended to show the customer the information "brand", "model" and "serial" first, as this most probably enables one to directly select the right device.

A.3 SHIP registration using post-trust

[SHIP] defines methods to "post-trust"*[1] a device. Even though this is not the recommended approach to trust another device, it will be described here briefly.

*[1]: The terms "pre-trust" and "post-trust" are first defined in [SHIP] version 1.1.0 but the principles already apply since [SHIP] version 1.0.0 as these terms are not related to concrete protocol details. For a SHIP device "A" with pre-trust, the user of device "A" needs to establish trust to another SHIP device "B" before applications on "A" will accept incoming SHIP connection attempts from "B". An example for a device "A" with pre-trust is the discovery of device "B" SKI(s) from its TXT record and TLS probing, display SKI(s) to the user and acceptance by the user.

If, on the other hand, device "A" permits post-trust, then it will first accept an incoming SHIP connection attempt from a yet untrusted device "B"*[2], but then asks the user to finally trust that device before further communication is possible*[3].

*[2]: This means device "A" accepts as TLS server received TLS client certificates without verification of their SKI/public key during the TLS handshake.

*[3]: The [SHIP] connection state "Hello" and its messages are designed to give a user time for verification of a yet untrusted certificate.

Post-trust requires careful implementation as this means that an unknown certificate must automatically be accepted during the TLS handshake and safely be discarded if the user does not accept this device/certificate.

A.4 Stronger requirements from regulation authorities

Vendors should consider that regulation authorities may impose stronger requirements on the communication security than those defined in [SHIP] or in this document. This holds esp. for interfaces to critical infrastructures like a GCPH. To give an example, devices offering grid-related Use Cases like "Limitation of Power Consumption" (LPC) to a GCPH may have to fulfil stronger requirements for certain regulatory cases as otherwise a GCPH may refuse connectivity.

The following list provides a non-exhaustive selection of [SHIP] aspects to verify against respective regulation requirements:

Initial trust information
By default, [SHIP] recommends to initially verify an SKI to trust the corresponding certificate. However, the operator of a critical infrastructure may instead require to receive a device's certificate (for a given curve) rather than the SKI of the certificate. In this case, the vendor of a device must enable the user to deliver the device's certificate (for a given curve).

Supported elliptic curves

[SHIP] requires and recommends several elliptic curves. Supporting additional curves is not further considered.

Supported cipher suites

[SHIP] lists the following cipher suites:

a) TLS_ECDHE_ECDSA_WITH_AES_128_CBC_SHA256
   This cipher suite SHALL be supported. But in case of critical infrastructures it might be required to use this cipher suite only in conjunction with the TLS extension "encrypt_then_mac" ([RFC7366]) (see below).
b) TLS_ECDHE_ECDSA_WITH_AES_128_GCM_SHA256
   Supporting this cipher suite is recommended!
c) TLS_ECDHE_ECDSA_WITH_AES_128_CCM_8
   This cipher suite SHOULD NOT be used ([SRIP-A40/1]). It is likely that regulation authorities prohibit its use for critical infrastructures. This cipher suite is also not recommended anymore by [RFC8447].

TLS extensions

In addition to TLS extensions mentioned in [SHIP]:

a) encrypt_then_MAC
   It is recommended to support the TLS extension "encrypt_then_MAC" ([RFC7366]) if cipher suites with CBC mode are used (see above). This extension might even be required by regulation authorities if such cipher suites are used in critical infrastructures.
b) truncated_hmac
   The TLS extension "truncated_hmac" SHOULD NOT be used ([SRIP-A40/2]). Regulation authorities may even prohibt using this TLS extension in critical infrastructures!

Lifetime of certificates

By default, [SHIP] does not impose strong requirements on the lifetime of certificates and its verification. However, vendors need to consider that stronger requirements are usually imposed by regulation authorities for critical infrastructures. Please consider Annex A.5 to mitigate or even overcome problems from expiry of certificates.

A.5 Seamless certificate updates via SHIP 1.1.0

The expiry of a certificate can cause communication problems. It is recommended to implement SHIP 1.1.0 as this version defines messages to mutually send certificate updates before expiry. Even though this requires the communication partner to support at least SHIP 1.1.0 as well, this recommendation can be seen as the most cost-effective option in the long term. Annex A.6 describes possibilities to implement just a subset of the extensions specified in SHIP 1.1.0.

Rationale: The acceptance of certificates with long lifetime is steadily declining, not just within critical infrastructures. But as SHIP is based upon trusted certificates, there is a need to distribute an updated certificate before it expires. SHIP 1.1.0 defines messages to send a certificate update to an already trusted device. This helps to keep a trusted relationship between devices without the need of trusting new certificates manually again.

Table 3 shows some more aspects on certificate lifetimes and potential dependencies on the type signature of a certificate.

Topic	SHIP	Regulation authority
Permitted lifetime of certificate	SHIP does not impose upper bounds on the lifetime of a certificate.	May impose certificate lifetimes of just a few years or even shorter.
Verify lifetime of certificate	SHIP permits accepting expired certificates. In such a case, SHIP recommends to treat an expired certificate like a self-signed certificate.	Usually less lax w.r.t. certificate lifetimes in case of PKI. But regulation authorities sometimes permit self-signed certificates for a particular device that is managed by an authorized role responsible for the security of the communication throughout the device's lifetime in a given installation. In such cases, regulation authorities rely on the role's maintenance responsibility and do NOT require verification of the lifetime of a self-signed certificate.
Self-signed certificates	Allowed	May require a PKI but usually also permit self-signed certificates if authenticated and maintained by a particular role.

Table 3: Comparison of some certificate requirements

A.6 Simplified implementation of SHIP 1.1.0

Version 1.1.0 of [SHIP] specifies a number of extensions, but many of them are optional. This section gives a guideline to help selecting a minimal set of extensions to implement.

1. Only elliptic curve secp256r1

As long as no external requirement (e.g. from a regulation authority) mandates support of the elliptic curves brainpoolP256r1 oder brainpoolP384r1, it is sufficient to implement only the elliptic curve secp256r1.

2. No TLS probing

As long as an implementation only supports the elliptic curve secp256r1, it is not necessary to implement TLS probing.

Rationale: TLS probing is only required if one of the optional curves mentioned in [SHIP][1.1.0] is implemented (in addition to secp256r1) and to consider certificate priorities used by the other device.

3. No support of "SHIP commissioning"

It is NOT generally necessary to support messages and functionality of the so-called "SHIP commissioning". Hence, it is not generally required to implement the following messages and functionalities:

- SME "commissioning request" message
- SME "commissioning response" message
- SME "key material request" message
- SME "key material" message
- SME "key material response" message
- SME "key material delete" message
- SME "key material delete response" message

4. Certificate update messages

The following messages and functionalities are required for the seamless certificate update possibility mentioned in Annex A.5 and SHALL be implemented by a device conforming to [SHIP][1.1.0]:

- SME "key material state" message
- SME "key material state response" message
- SME "key material state request" message

Summary: In the most simple case it is sufficient to consider item 4 together with some further small changes required by [SHIP][1.1.0] (ecc-key in TXT record; SKI in uppercase letters in TXT record; new requirements on element "keyMaterialState.updateCounter" in "SME hello" and on element "accessMethods.id").

Annex B - FAQ

B.1 "auto accept"

1. Pairing with "auto accept" as specified in [SHIP] – is this permissive?

[SHIP] describes a particular "auto accept" mode, but it is the least safe verification mode of SHIP. Therefore, it cannot be excluded that regulation authorities will prohibit "auto accept" for certain critical infrastructures.

Note: [SHIP] defines measures to reduce some risks of "auto accept": It is required to actively detect and avoid "mutual auto accept" situations; a device SHALL NOT be in "auto accept" mode for more than two minutes. But these measures might not be sufficient for all environments.

2. Can "auto accept" last longer than 2 minutes?

No. [SHIP] prohibits being in "auto accept" mode for more than 2 minutes (see section "Auto Accept" in [SHIP]).

3. Can "auto accept" complicate system installations?

Yes, potentially. Imagine a premises with one power consuming device C in "auto accept" mode. Furthermore, there are two devices A and B, each having EMS functionality. We also assume they have been configured to trust the SKI of C. Sophisticated EMS devices tend to automatically search for devices they can control to help the user with a simplification of the system setup. In such a case, it is unpredictable if A or B will gain control over C.

Please note that this problem is not specific to SHIP but to every protocol permitting "auto accept"-like pairings and automatisms.

4. Could installation processes benefit from a (future) "long-lasting auto accept" mode?

No. The problem described in question 3 would then persist for all the time. This means whether device C is controlled by device A or device B might change during runtime.

B.2 Alternative pairing concepts

1. Pairing without searching for SKIs via mDNS/DNS-SD – is this possible?

Yes, provided that an other SHIP device B tries to establish a connection repeatedly:

In general, [SHIP] requires to search for other devices as otherwise it cannot be guaranteed that two device will ever be able to connect with each other. Anyhow, here we assume [SHIP] device A does not search for other devices but device B is already configured to connect device A. In this case, device A has a TLS server port and will get a certificate of device B during the TLS handshake.

If "pre-trust" is required (i.e. "post-trust" is no option), device A then has to abort the TLS handshake with the yet unknown device B. However, it can save the SKI of the received certificate and present it to the user for acceptance or rejection (or even present other details of the certificate). If the user accepts this SKI and device B later retries to establish the connection, device A can complete the TLS handshake.

Note: At this time device A doesn't know the SHIP ID of device B. However, device A gets this information later via SME access methods identification (see [SHIP] for details).

Note: If device A supports more than one curve it might be necessary to store more than one SKI of device B. This can happen if device B itself supports more than one curve and performs a so-called TLS-probing at device A to determine the highest-ranked curve supported by both devices.